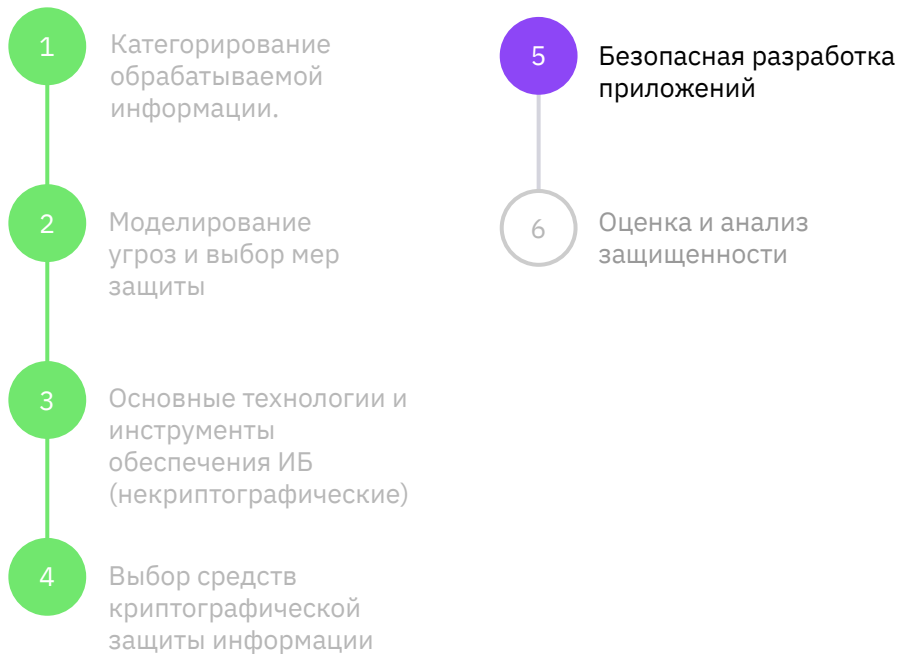


Основы информационной безопасности

Семинар 5. Безопасная разработка приложений



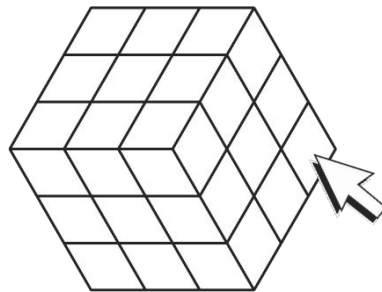
План семинаров “Основы информационной безопасности”





Что будет на уроке сегодня

- 📌 Повторение теории.
- 📌 Задания №1-3 «Input validation».
- 📌 Задание №4 «Output encoding».
- 📌 Задание №5 «Error handling and logging».
- 📌 Задание №6 «Authentication and password management».
- 📌 Домашнее задание.
- 📌 Подведение итогов.
- 📌 Рефлексия (самоанализ).



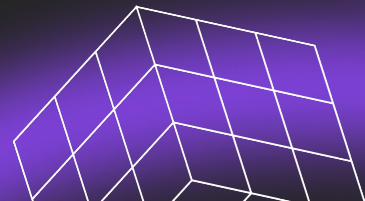


Повторение теории





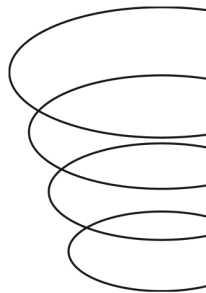
Какие рекомендации по безопасному
написанию кода вы помните?





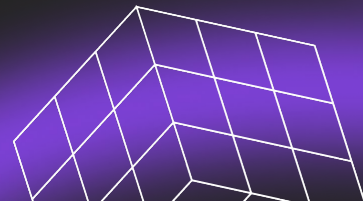
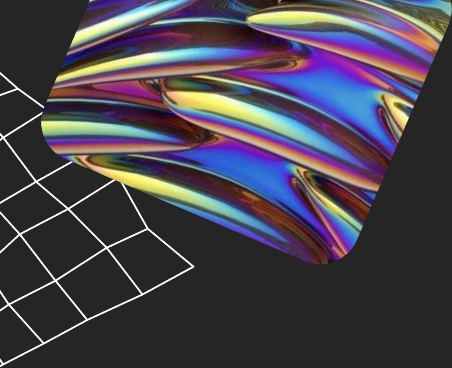
Какие рекомендации по безопасному написанию кода вы помните?

- 📌 Валидация входных данных (Input validation).
- 📌 Кодирование выходных данных (Output encoding).
- 📌 Аутентификация и управление паролями (Authentication and password management).
- 📌 Управление сессиями (Session management).
- 📌 Управление доступом (Access control).
- 📌 Криптографическая защита (Cryptographic practices).
- 📌 Обработка ошибок и регистрация событий (Error handling and logging).
- 📌 Защита данных (Data protection).
- 📌 Защита коммуникаций (Communication security).
- 📌 Безопасная конфигурация системы (System configuration).
- 📌 Безопасность баз данных (Database security).
- 📌 Безопасность файлов (File management).
- 📌 Безопасность данных в памяти (Memory management).





Примеры валидации входных данных (Input validation)



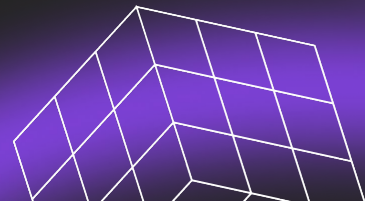
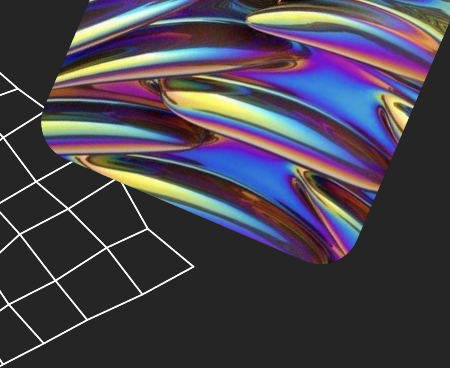


Примеры валидации входных данных (Input validation)?

-  Валидация всех данных, полученных из недоверенных источников.
-  Валидация диапазона данных.
-  Валидация длины данных.
-  Отклонение ввода в случае всех ошибок валидации .



Примеры кодирования выходных данных (Output encoding)





Примеры кодирования выходных данных (Output encoding)?

- 📌 Убедиться, что кодировка выходных данных безопасна для всех целевых систем.
- 📌 Контекстная санитизация (sanitize) всех выходных данных от недоверенных данных (входящих запросов) в исходящие SQL, XML и LDAP-запросы.
- 📌 Санитизация всех выходных данных от недоверенных данных в команды к операционной системе.





Задания





Задание №1 «Input validation»



Вам нужно сделать валидацию входных данных (Input validation) для умножения данных в заявке-заказе



5 минут

```
#Input validation
x = int(input('1st factor:'))
y = int(input('2nd factor:'))
print('Total =', x*y)
```

```
1st factor:5
2nd factor:4
Total = 20
```



Задание №1 (ответ*)

```
#Input validation
x = input('1st factor <= 10 digit number:')
y = input('2nd factor <= 10 digit number:')
while (len(x) > 10 or (not x.isdigit())) or (len(y) > 10 or (not y.isdigit())):
    print ('There is no 10 digit number')
    x = input('1st factor <= 10 digit number:')
    y = input('2nd factor <= 10 digit number:')
x = int(x)
y = int(y)
print('Total =', x*y)
```

```
1st factor <= 10 digit number:word
2nd factor <= 10 digit number:123
There is no 10 digit number
1st factor <= 10 digit number:12345678901
2nd factor <= 10 digit number:2
There is no 10 digit number
1st factor <= 10 digit number:5
2nd factor <= 10 digit number:4
Total = 20
```

* Возможны авторские
варианты ответов



Задание №2 «Input validation»



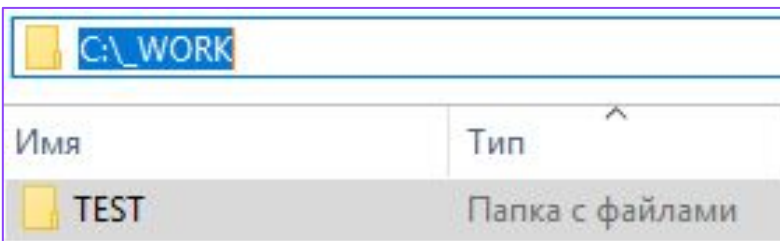
Вам нужно сделать валидацию входных данных (Input validation) и санитизацию выходных данных (Sanitize) в команды к операционной системе при создании каталогов для хранения материалов заявок-заказов

```
#Input validation + Output encoding (sanitization)
import os
input_path = input('Catalogue path:')
command = f'mkdir {input_path}'
os.popen(command)
```

Catalogue path:C:_WORK\\TEST



10 минут





Задание №2 (проблематика)

```
#Input validation + Output encoding (sanitization)
import os
input_path = input('Catalogue path:')
command = f'mkdir {input_path}'
os.popen(command)
```

Catalogue path:C:_WORK\\test1 & %windir%\\system32\\notepad.exe

We found 1 issues in your code

0 high severity 1 medium severity 0 low severity

Command Injection

VULNERABILITY | [CWE-78](#)

```
1 #Input validation + Output encoding (sanitization)
2 import os
3 input_path = input('Catalogue path:')
4 command = f'mkdir {input_path}'
5 os.popen(command)
```

Unsanitized input from user input flows into os.popen, where it is used as a shell command. This may result in a Command Injection vulnerability.



Безымянный — Блокнот

Файл Правка Формат Вид Справка

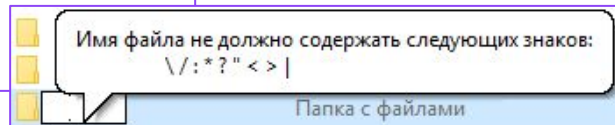
* <https://snyk.io/code-checker/python/>



Задание №2 (ответ*)

```
input_path = input('Catalogue path:')
spec_symbols = ['*', '?', '<', '>', '|', '&']
check = [characters in input_path for characters in spec_symbols]
while True in check:
    for i in range(len(check)):
        check[i] = False
    print('Incorrect catalogue path')
    input_path = input('Catalogue path:')
    check = [characters in input_path for characters in spec_symbols]
command = f'mkdir {input_path}'
os.popen(command)
print('Catalogue was successfully created')
```

```
Catalogue path:C:\\_WORK\\test?
Incorrect catalogue path
Catalogue path:C:\\_WORK\\test1 & %windir%\\system32\\notepad.exe
Incorrect catalogue path
Catalogue path:C:\\_WORK\\test2
Catalogue was successfully created
```



* Возможны авторские варианты ответов



Задание №3 «Input validation»

💡 Вам нужно сделать валидацию входных данных (Input validation) для блока с выполнением произвольного кода*

```
#Input validation (Arbitrary Code Execution)
compute_user_input = input('\nFactors and operator for computing: ')
if not compute_user_input:
    print ("No input")
else:
    print ("Result: ", eval(compute_user_input))
```

```
Factors and operator for computing: 5*4
Result: 20
```



5 минут

* Необходимость динамического выполнения кода (3 встроенные функции: **eval()**, **exec()** и **compile()**)



Задание №3 (ответ*)

```
#Input validation (Arbitrary Code Execution)
compute_user_input = input('\nFactors and operator for computing: ')
if not compute_user_input:
    print ("No input")
else:
    print ("Result: ", eval(compute_user_input, {'__builtins__':{}}))

Factors and operator for computing: __import__("os").popen('dir').read()

-----
NameError                                Traceback (most recent call last)
~\AppData\Local\Temp\ipykernel_18176\234424254.py in <module>
      4     print ("No input")
      5 else:
----> 6     print ("Result: ", eval(compute_user_input, {'__builtins__':{}}))

<string> in <module>

NameError: name '__import__' is not defined
```



Не использовать функцию `eval()` для ненадёжного источника ввода



Задание №4 «Output encoding»



Вам нужно сделать унифицированное преобразование выходных данных (Output encoding)



5 минут

```
#Output encoding
Name_input = input('\nFirst and last name: ')
print(f'Your data: {Name_input}')
```

```
First and last name: jon jones
Your data: jon jones
```

```
#Output encoding
Name_input = input('\nFirst and last name: ')
print(f'Your data: {Name_input}')
```

```
First and last name: JOn JOnes
Your data: JOn JOnes
```



Задание №4 (ответ*)

```
#Output encoding
Name_input = input('\nFirst and last name: ').title()
print(f'Your data: {Name_input}')
```

First and last name: jon jones
Your data: Jon Jones

```
#Output encoding
Name_input = input('\nFirst and last name: ').title()
print(f'Your data: {Name_input}')
```

First and last name: JOn JOnes
Your data: Jon Jones

```
#Output encoding
Name_input = input('\nFirst and last name: ').upper()
print(f'Your data: {Name_input}')
```

First and last name: JOn JOnes
Your data: JON JONES

```
#Output encoding
Name_input = input('\nFirst and last name: ').lower()
print(f'Your data: {Name_input}')
```

First and last name: JOn JOnes
Your data: jon jones

* Возможны авторские варианты ответов



Задание №5 «Error handling and logging»



Вам нужно расследовать попытки несанкционированного доступа при создании каталогов для хранения материалов заявок-заказов (Error handling and logging) – создать Log-файл

```
test_log.log — Блокнот
Файл  Правка  Формат  Вид  Справка
INFO:root:202===== 1=====:16.324175 Suspicious value: C:\\_WORK\\test?
INFO:root:202===== 1=====:34.835209 Suspicious value: C:\\_WORK\\test?
INFO:root:202===== 1=====:59.388801 Suspicious value: C:\\_WORK\\test & python --version
INFO:root:202===== 1=====:10.671440 Suspicious value: C:\\_WORK\\test & %windir%\\system32\\notepad.exe
```



10 минут



Задание №5 (ответ*)

```
import os
import logging
import datetime

logging.basicConfig(level=logging.DEBUG, filename='test_log.log', filemode='w')

input_path = input('Catalogue path:')
spec_symbols = ['*', '?', '<', '>', '|', '&']
check = [characters in input_path for characters in spec_symbols]
while True in check:
    for i in range(len(check)):
        check[i] = False
    logging.info(f'{datetime.datetime.now()} Suspicious value: {input_path}')
    print('Incorrect catalogue path')
    input_path = input('Catalogue path:')
    check = [characters in input_path for characters in spec_symbols]
command = f'mkdir {input_path}'
os.popen(command)
print('Catalogue was successfully created')
```

* Возможны авторские варианты ответов

Имя	Тип
 test_log.log	Текстовый документ



Задание №6 «Authentication and password management»

💡 Вам нужно безопасно сохранить пароли пользователей (Authentication and password management)

```
#Authentication and password management
dict_users = {'user1': 'password1', 'user2': 'password2'}
print(dict_users)

{'user1': 'password1', 'user2': 'password2'}
```



5 минут



Задание №6 (ответ*)

```
#Authentication and password management
import hashlib
dict_users = {'user1': 'password1', 'user2': 'password2'}
for i in dict_users:
    dict_users[i] = hashlib.sha256(dict_users[i].encode()).hexdigest()
print(dict_users)

{'user1': '0b14d501a594442a01c6859541bcb3e8164d183d32937b851835442f69d5c94e',
 'user2': '6cf615d5bcaac778352a8f1f3360d23f02f34ec182e259897fd6ce485d7870d4'}
```

```
#Authentication and password management
import bcrypt
dict_users = {'user1': 'password1', 'user2': 'password2'}
for i in dict_users:
    dict_users[i] = bcrypt.hashpw(dict_users[i].encode(), bcrypt.gensalt())
print(dict_users)

{'user1': b'$2b$12$ewoVFw4FMxB/0h2NCIDobeBidGM73PnFZpwzfNfdYLy4NIcAVZdmS',
 'user2': b'$2b$12$G2dguU8QKxonXjtSNzWYvOTJHHvZ/nK20b0a6saizw/HoB5GdjYxa'}
```

* Возможны авторские варианты ответов



Домашнее задание





Домашнее задание



Напишите программу на Python, которая будет проверять вводимый пользователем пароль на сложность (Authentication and password management):

- не менее 8 символов
- наличие прописных и строчных букв
- наличие цифр
- и переводит его в хэш-значение



Результат: файл формата .py или .ipynb





Вопросы?

Вопросы?



Вопросы?



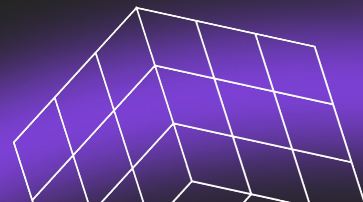
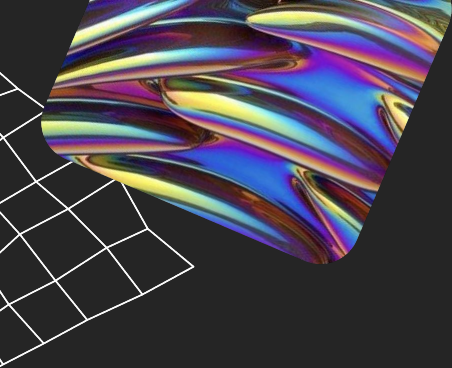


Подведем итоги



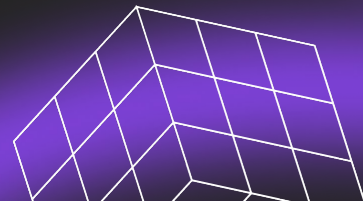
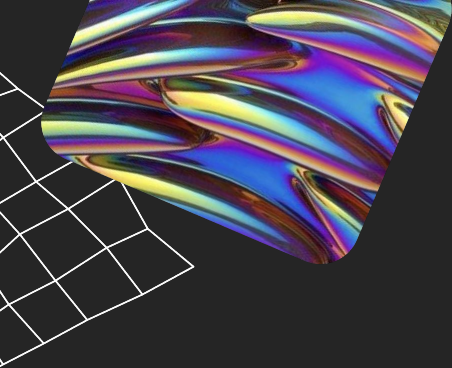


Что было сложного
на семинаре?



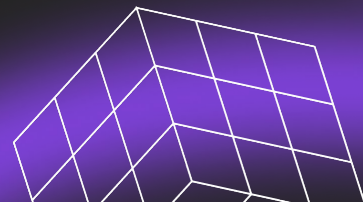
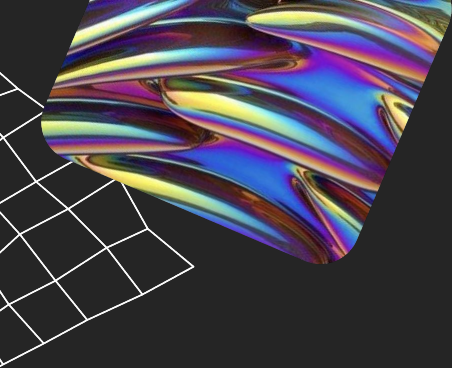


Напишите 3 вещи в комментариях,
которым вы научились сегодня.





Как настроение?





Спасибо за внимание

